TryHackMe Room Writeup 1 of 6

TryHackMe: Nmap

Network Traffic Analysis, Nmap and Windows Logging | Week 2 | Lab Part

Room detail	Details
Platform	TryHackMe
Room	Nmap
Room link	https://tryhackme.com/room/furthernmap
Public profile	https://tryhackme.com/p/hariniedward
Status	Completed, 100%
About the room	An in depth look at scanning with Nmap, a powerful network scanning tool.

Objective

I did this room to understand why every assessment starts with a port scan and how Nmap turns a list of ports into a picture of what a machine is running. It starts with the theory of ports, moves through the main switches and scan types, and ends with scripting, firewall evasion and a practical scan of a lab machine.

What I learned

- A computer has 65,535 ports, and each service listens on one of them. A scan reports a port as open, closed or filtered depending on how it answers.
- The core switches: -sS, -sT and -sU choose the scan type, -sV and -O detect service versions and the operating system, -v and -vv add detail, -oN, -oG and -oA save the results, -A turns on aggressive mode, -T0 to -T5 set the speed, and -p, -p- select ports.
- TCP connect, SYN and UDP scans each treat open, closed and filtered ports in a slightly different way.
- NULL, FIN and Xmas scans send unusual flag combinations. A closed port should answer with RST, an open one stays silent, and some systems such as Windows answer RST for everything.
- A ping sweep with -sn finds live hosts first, and -Pn skips that check when a firewall blocks ICMP.
- The Nmap Scripting Engine runs Lua scripts grouped into categories such as safe, vuln, auth, brute, discovery, intrusive and exploit. Intrusive scripts should never be run on a production system.
- Firewall evasion options include fragmenting packets with -f or --mtu, slowing the scan with --scan-delay, and sending bad checksums with --badsum to detect a firewall.

The scan types side by side

Scan	Switch	How it works	What I noted
TCP connect	-sT	Completes the full three way handshake with every port.	Works without root, but services can log the connections.
SYN	-sS	Sends SYN, then RST after a SYN-ACK, so the handshake is never finished.	Default with root. Faster, and often missed by application logs.
UDP	-sU	Sends UDP packets. A closed port returns an ICMP port unreachable message.	Slow, and silence means open or filtered. --top-ports saves time.
NULL, FIN, Xmas	-sN, -sF, -sX	Send packets with no flags, only FIN, or FIN, PSH and URG together.	Meant to slip past simple firewalls. Modern IDS tools spot them.
Ping sweep	-sn	Finds live hosts without scanning ports.	ARP on a local network, ICMP and TCP probes otherwise.

The practical task

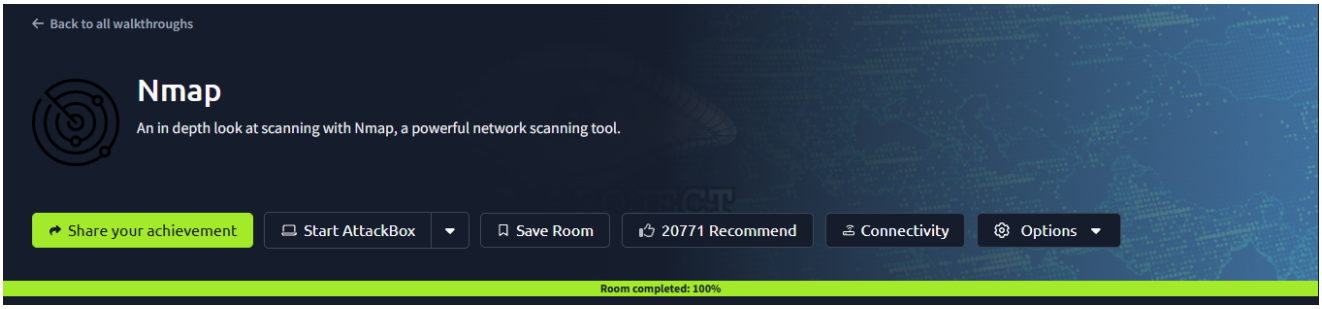
- Checked whether the lab machine answered ICMP echo requests.
- Ran an Xmas scan on the first 999 ports and read the reason Nmap gave for the result.
- Ran a SYN scan on the first 5000 ports to see which ports were open.
- Opened Wireshark, ran a TCP connect scan against port 80 and followed the packets it produced.
- Ran the ftp-anon script to find out whether anonymous FTP login was allowed.

Why this matters for a SOC analyst

- A SYN scan shows up as a burst of SYN packets to many ports, followed by RSTs. The filter tcp.flags.syn==1 && tcp.flags.ack==0 finds it quickly in Wireshark.
- The scan type decides where the evidence appears. Connect scans reach service logs, while SYN scans are more likely to appear only in firewall and IDS records.
- NULL, FIN and Xmas packets never occur in normal traffic, so they point strongly to scanning.
- Saving scan output with -oA gives a record I can use in a report.

> **Key takeaway**
> Seeing a scan from the attacker's side taught me what to look for from the defender's side. Each Nmap option leaves its own pattern on the wire, and learning those patterns is what makes detection possible.

Completion proof



Room page showing 100% completion. My profile details have been removed from the screenshot.

References

Room: https://tryhackme.com/room/furthernmap

My public profile: https://tryhackme.com/p/hariniedward